



Phishing REPORT

Table of Contents

Executive Summary	1
Scoping and Rules of Engagement	1
Client Risk Rating	2
Summary of Findings	2
Phishing Assessment Methodology	3
Overview	3
Phishing Attack Path.....	4
Phishing Email Scenario	7
Campaign Results	8

Executive Summary

Security is a journey, not a destination. One must remain vigilant, invest, and strive towards a robust security posture. The threat landscape is ever-changing, and malicious actors are always innovating. As the Internet becomes more hostile, defenders must enhance their capabilities as well.

As a proactive security measure, Molapo Cybersecurity hired a Pentester to perform a series of social engineering assessments against the organization. First, conducted the phishing assessment tests which were performed on 17 June 2026. The Pentester conducted social engineering tests which involving a Phishing email which was sent to the admin using a setoolkit.

Scoping and Rules of Engagement

The penetration tester conducted a targeted phishing attack for the organization as part of a controlled social engineering assessment. The primary objective of the engagement was defined in collaboration with the client and focused on evaluating specific security outcomes such as credential harvesting, measuring user interaction with malicious content, and simulating real-world attack behaviour. In more advanced scenarios, such assessments may also simulate post-compromise

activities such as credential reuse or data exfiltration attempts; however, for this project, the focus remained on capturing engagement metrics including link clicks and credential submission rates. The engagement scope was strictly limited to a single designated administrative user. The objective was to assess the user's ability to identify phishing indicators, exercise appropriate caution when interacting with suspicious communications, and apply basic security awareness practices in a realistic attack simulation.

No other employees, departments, systems, applications, or organizational assets were included within the scope of this assessment. Any activity beyond the authorized target was strictly prohibited under the agreed rules of engagement.

All testing activities were conducted in accordance with ethical hacking principles, explicit client authorization, and applicable legal and regulatory requirements, ensuring that the simulation remained controlled, safe, and compliant throughout the engagement.

Client Risk Rating

The Pentester calculated the risk to client based on exploitation likelihood (ease of exploitation) and potential impact (potential business impact to the environment).

Overall Risk Rating: High

Summary of Findings

During the phishing simulation exercise, the designated administrative user, Manuel, interacted with a crafted phishing email delivered as part of the controlled assessment. The email contained a malicious link designed to redirect the user to a simulated login portal that closely resembled a legitimate internal system. The user clicked on the embedded link without verifying its authenticity and was subsequently redirected to the controlled phishing landing page hosted within the testing environment.

Once on the landing page, the user proceeded to enter valid login credentials into the simulated authentication form. This action demonstrated successful exploitation of human trust factors, including insufficient verification of email legitimacy, lack of URL inspection, and limited awareness of phishing indicators such as domain inconsistencies and unexpected login prompts. The interaction was fully captured and logged as part of the engagement metrics for analysis.

The results of this assessment indicate a high level of susceptibility to phishing attacks for the tested user. The behaviour observed suggests gaps in security awareness training, particularly in identifying social engineering techniques and verifying the authenticity of authentication requests. No technical security controls were involved in preventing the interaction, indicating that the primary weakness lies in user awareness and decision-making rather than system-level defences.

Overall, the simulation successfully demonstrated how a realistic phishing attack could lead to credential compromise under similar conditions in a real-world environment. This finding highlights the need for strengthened security awareness programs, reinforced phishing recognition training, and the implementation of additional protective controls such as multi-factor authentication (MFA) and email filtering mechanisms.

Phishing Assessment Methodology

Overview

This phishing assessment methodology was developed as part of a controlled cybersecurity simulation project designed to evaluate user susceptibility to phishing attacks. The approach follows industry-aligned social engineering testing practices and is structured to replicate real-world attacker behaviour within an ethical and authorized testing environment.

The primary goal of this methodology is to measure how effectively users can identify, respond to, and report phishing attempts while maintaining strict rules of engagement and operational safety

1.OSINT Information Gathering - During the Open-Source Intelligence (OSINT) phase of the engagement, publicly available information was analyzed to identify potential attack vectors and assess the organization's exposure to social engineering threats. Information was collected from publicly accessible sources such as professional networking platforms and social media profiles to better understand user identity patterns and communication context relevant to the simulation. Through this process, details associated with the designated test account were identified, including the target's name, Manuel, and the email address Manuel073@gmail.com. These data points were used strictly within the authorized scope of the phishing simulation to design realistic and relevant attack scenarios. The information gathered during this phase supported the development of a more accurate pretext and was used solely for evaluating the effectiveness of security awareness controls and the target's ability to recognize phishing indicators in a controlled testing environment.

2. Target Analysis and Validation-In this phase, collected intelligence is verified and refined to ensure accuracy and realism.

Activities include:

- *Confirming target identity and role relevance*
- *Validating potential authentication portals or internal systems (simulated where necessary)*

- *Identifying high-value or relevant user interactions for testing*
- *Assessing likely trust vectors (e.g., IT support, internal HR communication)*
This step ensures that the phishing scenario closely reflects realistic organizational communication patterns

3.Execution - For this project, a simulated internal portal was created and hosted locally on 127.0.0.1:1000 to replicate the appearance and behaviour of a legitimate internal system within a controlled testing environment. This portal was designed solely for simulation purposes and did not represent any real organizational infrastructure or production service. In parallel, a separate phishing landing page was deployed on port 5678, which was used to emulate a realistic credential capture scenario as part of the social engineering assessment.



Figure 1.1 showing the company website running on 127.0.0.1:1000

Analysis and Reporting- After execution, all collected data is analysed to evaluate user behaviour and security awareness and then each target's results.

Phishing Attack Path

The objective of this engagement was to simulate a spear-phishing attack as closely as possible. The Pentester used a tool on Linux called setoolkit.

```
Session Actions Edit View Help
Shell No. 1

.o88o.          o8o          .
888  "          ""          .o8
o888oo .000o.o .0000o. .0000o. 0000 .0000o. .o888oo 0000 000
888  d88(  "8 d88" 88b d88"  Y8 888 d88" 88b 888  "88..8"
888  "Y88b, 888 888 888 888  Y8 888 888ooo888 888  "88..8"
888  o. )88b 888 888 888 .o8 888 888 .o 888 . "888"
o888o 8""888P' Y8bod8P' Y8bod8P' o888o Y8bod8P' "888" d8'
                                     .o...P'
                                     XERO'

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReLIX) [---]
[---] Version: 8.0.1 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.1
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set> 
```

Figure 1.2 shows setoolkit that was used for phishing attack.

```
Session Actions Edit View Help
Shell No. 1

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer
99. Return to main menu.

set:mailer>1

Do you want to use a predefined template or craft
a one time email template.

1. Pre-Defined Template
2. One-Time Use Email Template

set:phishing>2
set:phishing> Subject of the email: Security Updates
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: p
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished: Dear Manuel
Next line of the body: There is an security update on our system.
Next line of the body: Please log in to our website http://127.0.0.1:5678 to receive futher instructions.
Next line of the body: Regards
Next line of the body: IT support
Next line of the body: END
set:phishing> Send email to: Manuel123@gmail.com

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com): TSupport@Molapo-Cyber.com
set:phishing> The FROM NAME the user will see: IT support
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): 127.0.0.1
set:phishing> Port number for the SMTP server [25]: 1025
set:phishing> Flag this message/s as high priority? [yes/no]: yes
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
[*] SET has finished sending the emails

Press <return> to continue
```

Figure 1.3 shows how the setoolkit was configured to send a phishing email.

The screenshot illustrates that the phishing website closely resembled the legitimate internal portal in terms of structure and appearance, which contributed to user confusion. Although both sites were hosted on the same base address (**127.0.0.1**), they were differentiated by their respective ports, which served as the primary indicator of legitimacy. The phishing site used by the penetration tester was hosted on <http://127.0.0.1:5678>, while the legitimate internal portal operated on <http://127.0.0.1:1000>

This subtle difference in port numbers was intentionally used as part of the social engineering technique to increase the likelihood of user deception and credential submission. The similarity in layout and URL structure was designed to exploit a lack of technical awareness, ultimately leading the victim to unknowingly enter their credentials on the simulated phishing page.

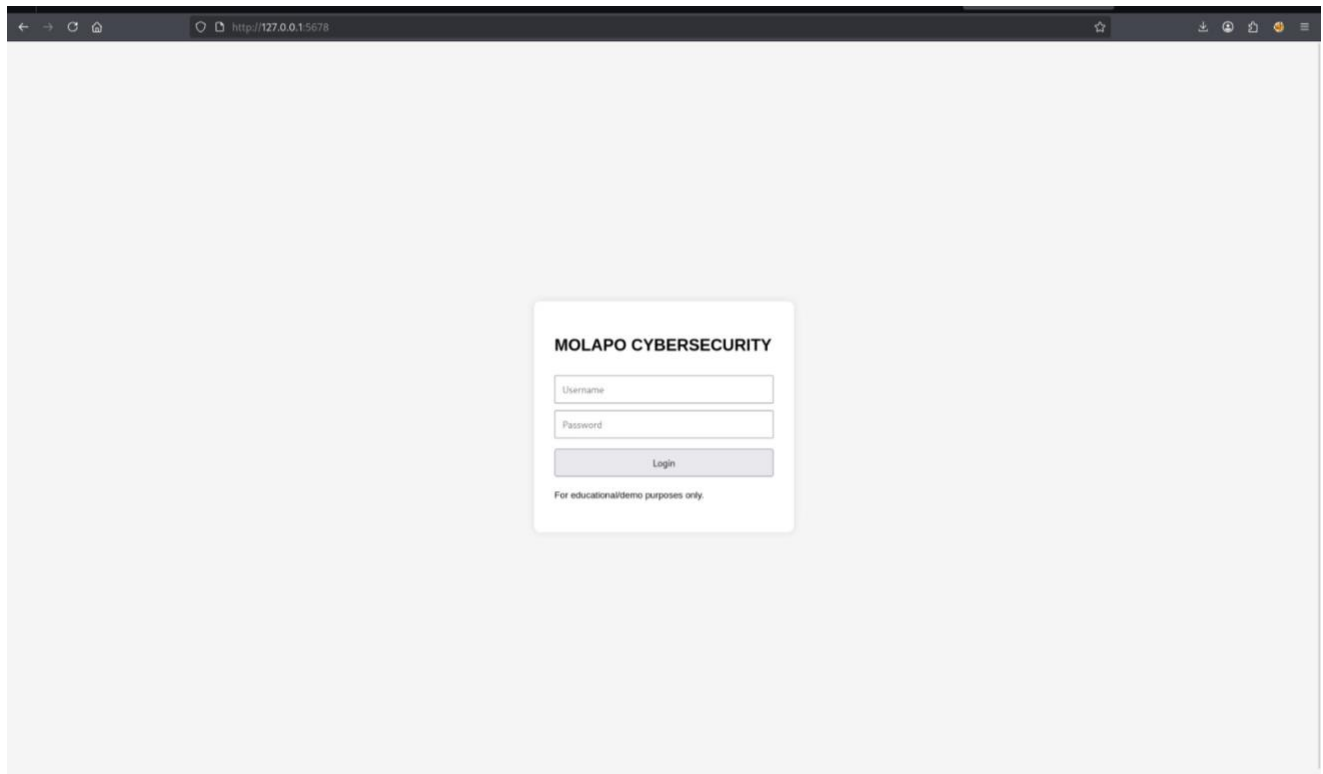


Figure 1.4 shows the same Company login portal but on a different port.

```
~ via 🐧 v3.13.12
> python3 server.py
Starting server on http://127.0.0.1:5678
```

Figure 1.5 shows that the penetration tester has initiated a listener on port 5678. This listener is configured to capture and display data submitted through the simulated phishing page, including any credentials entered by the target user.

Phishing Email Scenario



Figure 1.6 shows that the victim received two emails this is to display a source of urgency from the IT support.

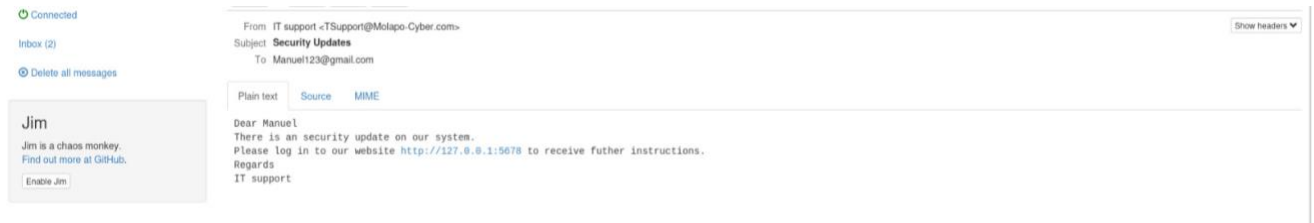


Figure 1.7 shows the phishing email that was delivered to the target user and subsequently interacted with. The user clicked on the embedded link, which was part of the simulated phishing campaign designed to evaluate security awareness and decision-making. This action indicates that the email was perceived as legitimate by the victim, leading to engagement with the malicious content. The interaction was recorded as part of the analysis to assess user susceptibility to phishing techniques and identify gaps in security awareness.

Phishing Campaign Results



Figure 1.8 shows that the target user entered their credentials into a simulated phishing website hosted on port 5678. The site was designed to closely resemble a legitimate internal login portal, which led the user to believe it was authentic. As a result, the victim unknowingly submitted sensitive credentials into the incorrect environment. This interaction demonstrates a successful phishing simulation outcome and highlights a lack of awareness regarding URL validation and authentication page verification.

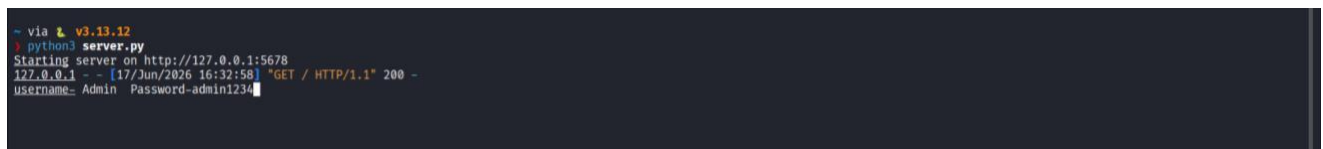


Figure 1.9 displays the captured administrator credentials on the listener server as part of the controlled phishing simulation. The information includes the username and password submitted by the target user through the simulated phishing page. This result confirms that the credential harvesting component of the engagement was successful within the authorized testing environment. The captured data was used strictly for analysis purposes to evaluate user susceptibility and identify gaps in security awareness and phishing detection skill